

attackers, like disgruntled employees, for instance, can set up their own MITM authentication system on the network, and divert traffic using IP spoofing and other techniques that we learnt about earlier. Victims who try to authenticate, reveal their credentials to the attacker.

- **Reflection attacks:** This is a very advanced type of attack, not necessarily limited to Web technology. It tries to exploit vulnerabilities in a customised challenge-response authentication system. The attacker first initiates a connection with the victim, which challenges the attacker for authentication, as usual. The attacker opens a fresh connection with the victim and sends its own challenge. Again, as usual, the target responds with a valid response. The attacker captures that response and sends it on the first initiated connection. Since both challenge and response fall in the victim's list of valid authentication parameters, it falls prey to this attack. This attack is rarely used in real life, but is common for weak public key encryption ciphers. Even simple SQL-based authentication systems that are not properly designed and lack intelligent error handling can be vulnerable to this form of attack.
- **Keylogger attacks:** In this well-known type of attack, a Trojan is sent to the user's machines, which quietly in the background, records all keystrokes and then emails a report of website URLs and credentials typed in to the attacker. Many modern spyware contain keyloggers, which could be stealing passwords.
- **Server-side authentication attacks:** So far, we have covered client-side and over-the-wire attacks. There can also be security challenges while a Web server or LDAP server is performing authentication. Usually, attackers would try to steal the administrator's password, to log in to the main authentication server—which would further reveal the entire credentials database. MITM attacks are often used to decipher information and gain access to the root system. Server-side attacks typically start with a script or a Trojan being installed on the server, which opens up stealth ports. The attacker then uses those ports to run commands on the server to fetch the required information. Even today, modern websites use SQL-based authentication or LDAP authentication that internally uses an SQL back-end for validation. Malformed Web requests, or running malicious scripts by exploiting an un-patched Web server, can let attackers steal SQL data, as we have learnt over this series of articles. Compromising these crucial servers can result in mass information and data theft.

Protecting FOSS systems

While authentication attacks are difficult to detect and tackle, there are a few preventive mechanisms that all

network administrators should adopt in their infrastructure. From the management's perspective, it is better to have a single corporate authentication system than multiple ones, because this means fewer attack points. The table shows multi-factor authentication technologies that can be used:

Authentication factor	Purpose	Example
First factor	What the user knows	Passwords, security questions
Second factor	What the user has	SecureID token, smart card
Third factor	What the user really is	Biometrics, retina scanner
Fourth factor	Where user is	GPS token

Using a strict and complex password scheme is usually the first line of defence. Password expiration policies and account lock policies are very important too. Encryption of passwords being stored on the centralised system is a must. All these help protect against manual or programmatic brute-force password attacks. Since authentication can be attacked from multiple sides, the authentication system needs to be properly designed and controlled, which will protect the systems from authentication bypass attack. Using IPSec and Kerberos can help prevent session stealing and hijacking. Tricks such as using session tokens, or time-stamping requests and performing error-handling based on time stamps, can help mitigate risk against authentication replay attacks. As for cookie interception attacks, using SSL or some sort of client- and server-side cookie encryption technique is recommended.

At the network layer, Linux FOSS systems come with a built-in feature called source address verification—a kernel feature that, when turned on, starts dropping packets that appear to be arriving from the internal network, but in reality, are not. Most recent kernels and distros like Ubuntu, CentOS, etc, do support it. If yours doesn't, it's time to upgrade! This usually helps reduce the chances of packet spoofing. Modifying `hosts.conf` to add "`nospoof on`" is another level of defence to try out. Needless to say, having a robust and automatic open source security patching system and anti-virus deployment is essential. 

By: Prashant Phatak

The author has over 20 years of experience in the field of IT hardware, networking, Web technologies and IT security. Prashant is MCSE and MCDBA certified and is also an F5 load balancer expert. In the IT security world, he is an ethical hacker and Net-forensic specialist. Prashant runs his own firm called Valency Networks in India (www.valencynetworks.com), providing consultancy in IT security design, security audits, infrastructure technology and business process management. He can be reached at prashant@valencynetworks.com.